

DAI HOC QUOC GIA THANH PHO HO CHI MINH  
TRUONG DAI HOC KHOA HOC TU NHIEU  
KHOA TOAN — TIN HOC

---

# BAO CAO THUC HANH

## Lab06 (Final): PHP Secure MVC Mini CRM

---

*Ung dung: EduCRM — Training Center CRM*

|                       |                   |
|-----------------------|-------------------|
| Giang vien huong dan: | TS. Tran Anh Tuan |
| Mon hoc:              | Lap trinh Web     |
| Sinh vien thuc hien:  | Le Pham Hong Hien |
| MSSV:                 | 22110059          |

---

TP. Ho Chi Minh, Thang 7/2026

# Contents

|          |                                                                                           |           |
|----------|-------------------------------------------------------------------------------------------|-----------|
| <b>1</b> | <b>Cau 1: Xay dung ung dung</b>                                                           | <b>3</b>  |
| 1.1      | Gioi thieu ung dung EduCRM . . . . .                                                      | 3         |
| 1.2      | Kiem tra moi truong (T01) . . . . .                                                       | 3         |
| 1.3      | Cau truc du an (T02) . . . . .                                                            | 3         |
| 1.4      | Front Controller va Router (T03) . . . . .                                                | 4         |
| 1.5      | Session / Login flow (T04, T11, T12) . . . . .                                            | 5         |
| 1.6      | Helpers va Layout/Partial (T05, T06) . . . . .                                            | 7         |
| 1.7      | Form cong khai an toan + chong spam (T07, T08, T09) . . . . .                             | 8         |
| 1.8      | Thiet ke database (T13, T14) . . . . .                                                    | 10        |
| 1.9      | Ket noi PDO chuan (T15) . . . . .                                                         | 11        |
| 1.10     | Repository — prepared statements (T16) . . . . .                                          | 11        |
| 1.11     | MVC dung trach nhien: vi du Controller -> Service -> Repository (T17, T18, T19) . . . . . | 12        |
| 1.12     | CRUD Module A va Module B (T20, T22) . . . . .                                            | 14        |
| 1.13     | Duplicate handling (T21, T23) . . . . .                                                   | 15        |
| 1.14     | Search / Pagination / Sort an toan (T24, T25) . . . . .                                   | 16        |
| 1.15     | Health JSON, 404/405 va Safe error + logging (T26–T28) . . . . .                          | 18        |
| 1.16     | EXPLAIN / index (T29) . . . . .                                                           | 19        |
| 1.17     | GitHub / README (T30) . . . . .                                                           | 21        |
| 1.18     | Bang route day du . . . . .                                                               | 21        |
| <b>2</b> | <b>Checklist task T01–T30 va Test Result TC01–TC25</b>                                    | <b>22</b> |
| 2.1      | Checklist task nho T01–T30 . . . . .                                                      | 22        |
| 2.2      | Bang Test Result TC01–TC25 . . . . .                                                      | 23        |
| <b>3</b> | <b>Cau 2: Problem Solving</b>                                                             | <b>25</b> |
| 3.1      | Front Controller & Router . . . . .                                                       | 25        |
| 3.2      | Secure form . . . . .                                                                     | 25        |
| 3.3      | PRG Pattern . . . . .                                                                     | 25        |
| 3.4      | Anti-spam co ban . . . . .                                                                | 25        |
| 3.5      | Session/login flow . . . . .                                                              | 25        |
| 3.6      | Logout, timeout va cookie flags . . . . .                                                 | 26        |
| 3.7      | Remember me . . . . .                                                                     | 26        |
| 3.8      | Database schema . . . . .                                                                 | 26        |
| 3.9      | Prepared statements . . . . .                                                             | 26        |
| 3.10     | Unique constraint & duplicate handling . . . . .                                          | 26        |
| 3.11     | Search/pagination/sort safe . . . . .                                                     | 27        |
| 3.12     | Index & EXPLAIN . . . . .                                                                 | 27        |
| 3.13     | MVC dung trach nhien . . . . .                                                            | 27        |
| 3.14     | Layout/Partial & XSS . . . . .                                                            | 27        |
| 3.15     | Dev/prod error message . . . . .                                                          | 27        |
| 3.16     | 404 vs 405 . . . . .                                                                      | 27        |
| 3.17     | Delete bang POST . . . . .                                                                | 28        |
| 3.18     | Huong phat trien that . . . . .                                                           | 28        |

|          |                                                          |           |
|----------|----------------------------------------------------------|-----------|
| <b>4</b> | <b>Tinh nang mo rong nang cao va giao dien hien dai</b>  | <b>29</b> |
| 4.1      | F1 — Chuyen Lead thanh Phieu thu (transaction) . . . . . | 29        |
| 4.2      | F2 — Soft delete + Thung rac (Restore) . . . . .         | 29        |
| 4.3      | F3 — Audit log (nhat ky hoat dong) . . . . .             | 30        |
| 4.4      | F4 — Export CSV an toan . . . . .                        | 31        |
| 4.5      | F5 — Dashboard analytics . . . . .                       | 31        |
| 4.6      | Giao dien hien dai (redesign) . . . . .                  | 33        |
| 4.7      | Tinh nang F6–F11 (CRM nang cao) . . . . .                | 33        |
| 4.8      | Bangkiem thu tinh nang mo rong (verify live) . . . . .   | 35        |
| 4.9      | Problem Solving (tinh nang moi) . . . . .                | 35        |
| <b>5</b> | <b>Ket luan</b>                                          | <b>36</b> |

# 1 Cau 1: Xay dung ung dung

## 1.1 Gioi thieu ung dung EduCRM

Em chon xay dung mot **Secure MVC Mini CRM** cho bai toan **Training Center CRM** — dat ten la **EduCRM**. EduCRM la he thong quan ly tu van va hoc phi cho mot trung tam dao tao, gom hai nghiep vu chinh:

- **Module A — Lead (/leads)**: quan ly lead tu van / hoc vien tiem nang (ho ten, email, so dien thoai, khoa hoc quan tam, nguon, trang thai cham soc).
- **Module B — Phieu hoc phi / Order (/orders)**: quan ly phieu thanh toan hoc phi gan voi tung lead, co `order_code` duy nhat va trang thai thanh toan.

Ngoai ra co **form dang ky tu van cong khai** (/public-leads/create) cho khach truy cap, **dang nhap nhan vien** bang session va **dashboard thong ke**. Du an khong giu lai bai mau generic: ten project, database (`training_center_crm`), bang, cot, route, controller, service, repository, view, du lieu mau va thong bao loi deu duoc dat lai theo bai toan trung tam dao tao.

## 1.2 Kiem tra moi truong (T01)

- **PHP**: 8.2.12 (XAMPP), chay qua `php -S 127.0.0.1:8106 -t public`.
- **MySQL**: MariaDB/MySQL trong XAMPP, user `root`, database `training_center_crm`.
- **Autoload**: PSR-4 App\ -> app/ (khong can Composer global).
- **Cong cu test**: `curl` (kiem tra route, status code, redirect, JSON).
- **Git/GitHub**: <https://github.com/lphhien112-gif/PHP->

*[Anh chup man hinh] Terminal `php -v`, `mysql -e "SELECT 1"` va cay thu muc trong VS Code (T01, T02).*

## 1.3 Cau truc du an (T02)

EduCRM/

```
|-- public/
|   |-- index.php           # Front Controller (entry point duy nhat)
|   '-- assets/app.css      # Stylesheet
|-- config/
|   |-- app.php             # debug, timeout, rate limit, whitelist khoa hoc/trang t
|   '-- database.php        # thong tin ket noi MySQL
|-- app/
|   |-- Core/
|       |-- Database.php    # PDO singleton chuan
|       |-- Router.php      # map METHOD+PATH; 404/405
|       |-- helpers.php     # e, redirect, render, partial, flash, old, i
|       '-- DuplicateRecordException.php # loi trung UNIQUE -> field error
```

```

|   |-- Controllers/           # THIN: doc request -> Service -> render/redirect
|   |   |-- AuthController.php
|   |   |-- DashboardController.php
|   |   |-- PublicLeadController.php
|   |   |-- LeadController.php      # Module A
|   |   |-- OrderController.php     # Module B
|   |   '-- HealthController.php
|   |-- Services/              # business rule: validate, pagination, duplicate
|   |   |-- AuthService.php
|   |   |-- LeadService.php
|   |   '-- OrderService.php
|   |-- Repositories/          # TAT CA SQL (prepared statement, không doc $_POST)
|   |   |-- UserRepository.php
|   |   |-- LeadRepository.php
|   |   '-- OrderRepository.php
|   '-- Views/                 # chi hien thi, escape bang e()
|       |-- layouts/{main,auth,public,error}.php
|       |-- partials/{nav,flash}.php
|       |-- auth/login.php
|       |-- dashboard/index.php
|       |-- leads/{index,create,edit}.php
|       |-- orders/{index,create,edit}.php
|       |-- public-leads/create.php
|       '-- errors/{404,405,500}.php
|-- database/{schema.sql, seed.sql}
|-- storage/logs/app.log
|-- vendor/                    # PSR-4 autoload (App\ -> app/)
'-- README.md

```

## 1.4 Front Controller va Router (T03)

Moi request deu di qua public/index.php. File nay: (1) cho php -S phuc vu file tinh, (2) khai tao session voi cookie flags an toan, (3) load autoload + helpers, (4) khai bao toan bo route tap trung, (5) dispatch trong khoi try/catch de xu ly loi an toan.

Listing 1: public/index.php — khai bao route (rut gon)

```

$router = new Router();
$router->get('/login', [$auth, 'loginForm']);
$router->post('/login', [$auth, 'handleLogin']);
$router->post('/logout', [$auth, 'logout']);
$router->get('/dashboard', [$dashboard, 'index']);
$router->get('/public-leads/create', [$publicLd, 'create']);
$router->post('/public-leads', [$publicLd, 'store']);
// Module A - Leads
$router->get('/leads', [$leads, 'index']);
$router->post('/leads/store', [$leads, 'store']);
$router->post('/leads/delete', [$leads, 'delete']);
// Module B - Orders
$router->get('/orders', [$orders, 'index']);
$router->post('/orders/store', [$orders, 'store']);
// Health JSON

```

```

$router->get('/health', [$health, 'index']);

$router->setNotFoundHandler(fn() => render_error(404, '404'));
$router->setMethodNotAllowedHandler(fn($a) => render_error(405, '405',
    , ['allowed'=>$a]));

```

`Router::dispatch()` phân biệt rõ **404** (path không tồn tại) và **405** (path tồn tại nhưng sai method, kèm header Allow):

Listing 2: `app/Core/Router.php` — `dispatch()`

```

public function dispatch(string $requestMethod, string $requestPath):
    void
{
    $requestMethod = strtoupper($requestMethod);
    $requestPath   = $this->normalize($requestPath);

    // Buoc 1: khop chinh xac METHOD + PATH
    foreach ($this->routes as $route) {
        if ($route['method'] === $requestMethod && $route['path'] ===
            $requestPath) {
            call_user_func($route['handler']); return;
        }
    }

    // Buoc 2: path ton tai nhung khac method -> 405 + Allow
    $allowed = [];
    foreach ($this->routes as $route) {
        if ($route['path'] === $requestPath) { $allowed[] = $route['
            method']; }
    }
    if (!empty($allowed)) {
        header('Allow: ' . implode(', ', array_unique($allowed)));
        call_user_func($this->methodNotAllowedHandler, $allowed);
        return;
    }

    // Buoc 3: path khong ton tai -> 404
    call_user_func($this->notFoundHandler);
}

```

*[Anh chụp màn hình] Code `public/index.php` và `Router.php` trong VS Code (T03).*

## 1.5 Session / Login flow (T04, T11, T12)

Trước `session_start()`, Front Controller gọi `session_set_cookie_params()` để đặt cookie flags an toàn:

Listing 3: `public/index.php` — cookie flags an toàn

```

$isHttps = (!empty($_SERVER['HTTPS']) && $_SERVER['HTTPS'] !== 'off')
    || (($_SERVER['SERVER_PORT'] ?? null) == 443);

```

```

session_set_cookie_params([
    'lifetime' => 0,
    'path'     => '/',
    'secure'   => $isHttps, // Secure khi HTTPS (production)
    'httponly' => true,     // JS không đọc được cookie -> giảm XSS
                        steal
    'samesite' => 'Lax',    // giảm CSRF cross-site
]);
session_start();

```

Flow đăng nhập dùng: validate input -> verify password -> `session_regenerate_id(true)` -> set session -> flash -> redirect /dashboard. Logic password/session nằm ở AuthService, controller chi điều phối:

Listing 4: app/Services/AuthService.php — attempt() và login()

```

public function attempt(string $username, string $password): array
{
    $username = trim($username);
    if ($username === '' || $password === '')
        return ['ok'=>false, 'error'=>'Vui lòng nhập đầy đủ tên đăng
            nhập và mật khẩu.'];
    $user = $this->users->findByUsername($username);
    if (!$user || !password_verify($password, $user['password_hash']))
    {
        log_app('warning', 'Login failed for username=' . $username);
        return ['ok'=>false, 'error'=>'Tên đăng nhập hoặc mật khẩu
            không đúng.'];
    }
    return ['ok'=>true, 'user'=>[...]];
}

public function login(array $user): void
{
    session_regenerate_id(true); // chống session fixation
    $_SESSION['user']           = $user;
    $_SESSION['login_at']       = time();
    $_SESSION['last_activity']  = time();
}

```

Logout xóa sạch session data, xóa cookie session và destroy:

Listing 5: app/Services/AuthService.php — logout()

```

public function logout(): void
{
    $_SESSION = [];
    if (ini_get('session.use_cookies')) {
        $p = session_get_cookie_params();
        setcookie(session_name(), '', time() - 42000,
            $p['path'], $p['domain'], $p['secure'], $p['httponly']);
    }
    session_destroy();
}

```

**Idle timeout:** helper `require_login()` kiểm tra `last_activity`; nếu không hoạt động qua 1800 giây (30 phút) sẽ đăng xuất và redirect /login kèm flash.

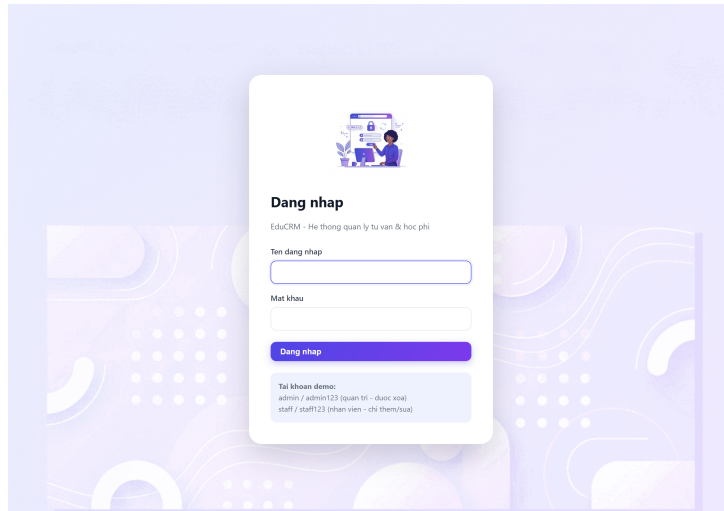


Figure 1: Form dang nhap (GET /login): co CSRF token an, tai khoan demo, login dung se redirect sang dashboard (T10, T11).

## 1.6 Helpers va Layout/Partial (T05, T06)

Cac helper bat buoc duoc dinh nghia trong `app/Core/helpers.php`: `e()`, `redirect()`, `render()`, `partial()`, `flash()/get_flash()`, `old()`, `require_login()`; bo sung `csrf_token()`, `csrf_field()`, `verify_csrf()`, `log_app()`.

Listing 6: `helpers.php` — `render()` lap view con vao layout chung

```
function render(string $view, array $data = [], ?string $layout = '
    layouts/main'): string
{
    extract($data, EXTR_SKIP);
    ob_start(); require view_path($view); $content = ob_get_clean();
    if ($layout === null) return $content;
    ob_start(); require view_path($layout); return ob_get_clean();
}
function e(?string $value): string {
    return htmlspecialchars((string)$value, ENT_QUOTES |
        ENT_SUBSTITUTE, 'UTF-8');
}
```

Layout `layouts/main.php` dung chung header (nav) + flash; view con khong lap lai HTML header/footer. Partial `partials/nav.php` va `partials/flash.php` duoc nhung qua `partial()`.

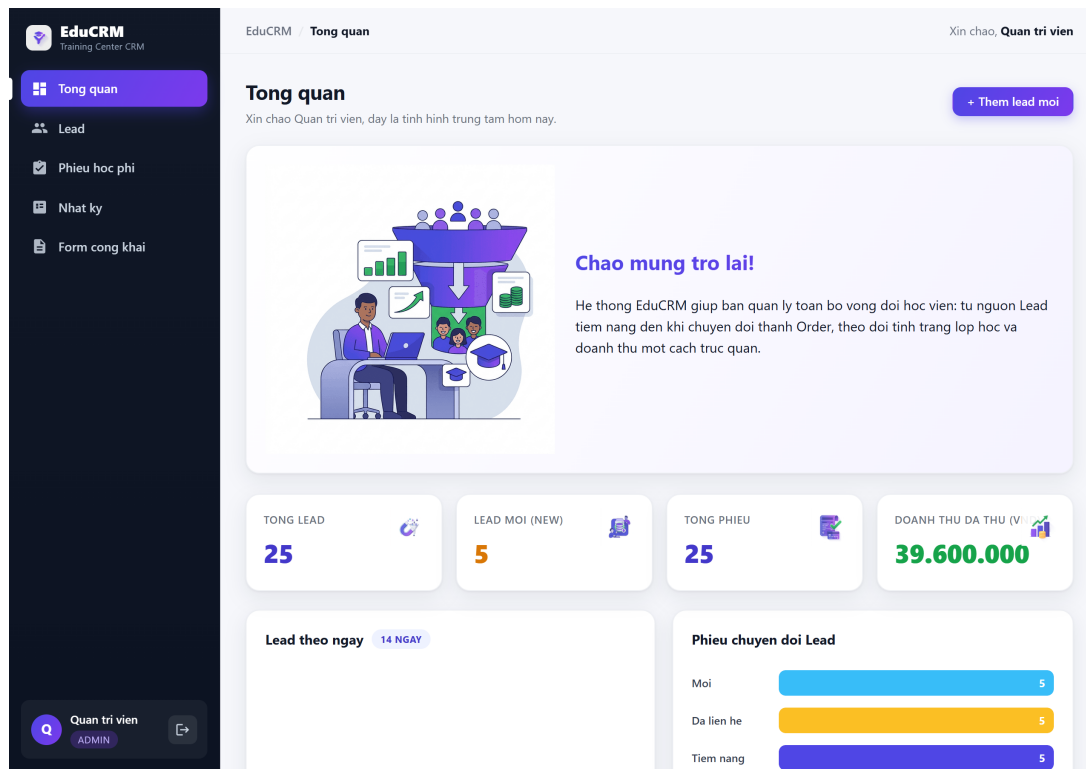


Figure 2: Dashboard EduCRM sau khi dang nhap: layout chung + nav + thong ke (tong lead/order, doanh thu, lead theo trang thai) (T06).

## 1.7 Form cong khai an toan + chong spam (T07, T08, T09)

PublicLeadController::store() thuc hien tuan tu: (1) kiem tra honeypot, (2) rate limit theo session, (3) validate server-side qua LeadService, (4) PRG sau khi thanh cong.

Listing 7: app/Controllers/PublicLeadController.php — store() (rut gon)

```
// 1. Honeypot: field an "website" phai rong. Bot thuong dien het field.
if (trim((string)($_POST['website'] ?? '')) !== '') {
    log_app('warning', 'Honeypot triggered ...');
    flash('success', 'Cam on ban, chung toi se lien he som!'); // gia
    vo thanh cong
    redirect('/public-leads/create');
}
// 2. Rate limit theo session (toi da 5 lan / 300 giay)
if ($this->isRateLimited()) {
    flash('error', 'Ban gui qua nhanh. Vui long thu lai sau vai phut.
    ');
    set_old($_POST, []); redirect('/public-leads/create');
}
// 3. Validate server-side + old input khi loi
$result = $this->leads->create($input, 'new');
if (!$result['ok']) {
    set_old($input, $result['errors']);
    redirect('/public-leads/create');
}
// 4. PRG: redirect sau POST thanh cong -> F5 khong tao trung
```

```
$this->recordSubmission();  
flash('success', 'Đăng ký thành công! ...');  
redirect('/public-leads/create');
```

Validate server-side (trong `LeadService::validate()`) kiểm tra: required, định dạng email (filter\_var FILTER\_VALIDATE\_EMAIL), số điện thoại (regex `/^\d{9,10}$`), độ dài, và course phải nằm trong whitelist khoa học.

**EduCRM**  
Trung tâm đào tạo - Đăng ký tư vấn khoa học miễn phí

**Đăng ký nhận tư vấn**  
Điền thông tin, đôi ngũ tư vấn của chúng tôi sẽ liên hệ trong 24h.

Họ tên \*

Email \*

Số điện thoại \*

Khoa học quan tâm \*  
-- Chọn khoa học --

Figure 3: Form công khai GET `/public-leads/create`: có honeypot an, layout public riêng (T07).

**EduCRM**  
Trung tâm đào tạo - Đăng ký tư vấn khoa học miễn phí

Vui lòng kiểm tra lại thông tin đã nhập.

**Đăng ký nhận tư vấn**  
Điền thông tin, đôi ngũ tư vấn của chúng tôi sẽ liên hệ trong 24h.

Họ tên \*

Email \*

Số điện thoại \*

Khoa học quan tâm \*  
-- Chọn khoa học --

Vui lòng nhập email.

Figure 4: Validate server-side: submit thiếu field bắt buộc -> lỗi theo từng field và giữ lại old input (Bob) (T08).

## 1.8 Thiet ke database (T13, T14)

Database training\_center\_crm co 3 bang: users, leads, orders. Tat ca dung engine InnoDB, charset utf8mb4\_unicode\_ci, co created\_at / updated\_at.

Listing 8: database/schema.sql — bang leads (Module A)

```
CREATE TABLE leads (
  id          INT UNSIGNED NOT NULL AUTO_INCREMENT,
  full_name   VARCHAR(120) NOT NULL,
  email       VARCHAR(150) NOT NULL,
  phone       VARCHAR(20)  NOT NULL,
  course      VARCHAR(80)  NOT NULL,
  source      VARCHAR(40)  NOT NULL DEFAULT 'website',
  status      ENUM('new','contacted','qualified','converted','lost')
              NOT NULL DEFAULT 'new',
  note        VARCHAR(500) NULL,
  created_at  TIMESTAMP NOT NULL DEFAULT CURRENT_TIMESTAMP,
  updated_at  TIMESTAMP NOT NULL DEFAULT CURRENT_TIMESTAMP ON UPDATE
              CURRENT_TIMESTAMP,
  PRIMARY KEY (id),
  UNIQUE KEY uq_leads_email (email),           -- chong trung email
  lead
  KEY idx_leads_status (status),               -- ho tro filter theo
  status
  KEY idx_leads_course (course),
  KEY idx_leads_created_at (created_at)       -- ho tro sort mac dinh
  moi nhat
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci;
```

Listing 9: database/schema.sql — bang orders (Module B)

```
CREATE TABLE orders (
  id          INT UNSIGNED NOT NULL AUTO_INCREMENT,
  order_code  VARCHAR(30)  NOT NULL,
  lead_id     INT UNSIGNED NOT NULL,
  course      VARCHAR(80)  NOT NULL,
  amount      DECIMAL(12,2) NOT NULL DEFAULT 0,
  status      ENUM('pending','paid','refunded','cancelled') NOT NULL
              DEFAULT 'pending',
  paid_at     DATE NULL,
  note        VARCHAR(500) NULL,
  created_at  TIMESTAMP NOT NULL DEFAULT CURRENT_TIMESTAMP,
  updated_at  TIMESTAMP NOT NULL DEFAULT CURRENT_TIMESTAMP ON UPDATE
              CURRENT_TIMESTAMP,
  PRIMARY KEY (id),
  UNIQUE KEY uq_orders_code (order_code),     -- chong trung ma phieu
  KEY idx_orders_status (status),
  KEY idx_orders_lead_id (lead_id),
  KEY idx_orders_created_at (created_at),
  CONSTRAINT fk_orders_lead FOREIGN KEY (lead_id) REFERENCES leads
  (id)
  ON DELETE CASCADE ON UPDATE CASCADE
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci;
```

Khoa va rang buoc:

- Primary key: users.id, leads.id, orders.id (auto increment).

- **Unique:** users.username, leads.email, orders.order\_code.
- **Foreign key:** orders.lead\_id -> leads.id (ON DELETE CASCADE).
- **Index:** status, course, lead\_id, created\_at.
- **Timestamp:** created\_at, updated\_at (auto cap nhat).

Seed (T14): 2 tai khoan demo (admin/admin123, staff/staff123 — mat khau password\_hash bcrypt) + **25 leads** + **25 orders** de test pagination. Kiem chung: SELECT COUNT(\*) cho ket qua users=2, leads=25, orders=25.

[Anh chup man hinh] File *schema.sql* va *SELECT COUNT(\*)* ket qua 2/25/25 (T13, T14).

## 1.9 Ket noi PDO chuan (T15)

Listing 10: app/Core/Database.php — PDO chuan

```
$options = [
    PDO::ATTR_ERRMODE          => PDO::ERRMODE_EXCEPTION,
    PDO::ATTR_DEFAULT_FETCH_MODE => PDO::FETCH_ASSOC,
    PDO::ATTR_EMULATE_PREPARES => false, // prepared statement
                                native MySQL
];
$dsn = "mysql:host=127.0.0.1;port=3306;dbname=training_center_crm;
        charset=utf8mb4";
self::$instance = new PDO($dsn, 'root', '', $options);
```

Luu y ky thuat (gap that khi build): voi EMULATE\_PREPARES=false, MySQL native prepared statement **khong cho dung lai** mot named placeholder nhieu lan. Ban dau em viet LIKE :q OR ... LIKE :q (3 lan) gay loi HY093 Invalid parameter number. Em da sua: moi cot mot placeholder riêng (:q\_name, :q\_email, :q\_phone).

## 1.10 Repository — prepared statements (T16)

Toan bo SQL nam o Repository, dung prepare/execute/bindValue, khong noi truc tiep input vao SQL.

Listing 11: app/Repositories/LeadRepository.php — create() (INSERT prepared)

```
public function create(array $data): int
{
    $sql = 'INSERT INTO leads (full_name, email, phone, course,
        source, status, note)
        VALUES (:full_name, :email, :phone, :course, :source, :
            status, :note)';

    try {
        $stmt = $this->db()->prepare($sql);
        $stmt->execute([
            ':full_name' => $data['full_name'], ':email' => $data['
                email'],
```

```

        ':phone' => $data['phone'], ':course' => $data['course'],
        ':source' => $data['source'], ':status' => $data['status']
    ],
    ':note' => $data['note'],
    ]);
    return (int) $this->db()->lastInsertId();
} catch (PDOException $e) {
    if ($this->isDuplicate($e))
        throw new DuplicateRecordException('email', 'Email nay da
            ton tai trong he thong.');
```

Listing 12: app/Repositories/LeadRepository.php — paginate() (SELECT prepared + whitelist sort)

```

public function paginate(string $q, string $status, string $sort,
    string $dir,
    int $limit, int $offset): array
{
    // Lop bao ve thu 2: whitelist cot + direction TRUOC khi ghep
    ORDER BY
    $sort = in_array($sort, self::SORTABLE, true) ? $sort : '
        created_at';
    $dir = strtoupper($dir) === 'ASC' ? 'ASC' : 'DESC';
    [$where, $params] = $this->buildWhere($q, $status);

    $sql = "SELECT id, full_name, email, phone, course, source,
        status, note, created_at
        FROM leads $where ORDER BY $sort $dir LIMIT :limit OFFSET
            :offset";
    $stmt = $this->db()->prepare($sql);
    foreach ($params as $k => $v) $stmt->bindValue($k, $v, PDO::
        PARAM_STR);
    $stmt->bindValue(':limit', $limit, PDO::PARAM_INT);
    $stmt->bindValue(':offset', $offset, PDO::PARAM_INT);
    $stmt->execute();
    return $stmt->fetchAll();
}
```

## 1.11 MVC dung trach nhien: vi du Controller -> Service -> Repository (T17, T18, T19)

De chung minh Controller khong viet SQL va View khong query DB, xet luong tao lead:

(1) Controller (mong) — chi doc request, goi service, render/redirect:

Listing 13: app/Controllers/LeadController.php — store()

```

public function store(): void
{
    require_login();
    if (!verify_csrf()) { flash('error', 'Phien khong hop le (CSRF).');
        redirect('/leads/create'); }
```

```

    $result = $this->leads->create($_POST, $_POST['status'] ?? 'new')
    ;
    if (!$result['ok']) {
        set_old($_POST, $result['errors']);
        flash('error', 'Khong the tao lead. Vui long kiem tra lai.');
```

(2) **Service** — giu business rule: validate, sanitize, bat duplicate:

Listing 14: app/Services/LeadService.php — create()

```

public function create(array $input, string $defaultStatus = 'new'):
    array
{
    $errors = $this->validate($input);           // validate server-
        side
    if ($errors) return ['ok'=>false, 'errors'=>$errors];
    $data = $this->sanitize($input, $defaultStatus);
    try {
        $id = $this->repo->create($data);
        return ['ok'=>true, 'id'=>$id];
    } catch (DuplicateRecordException $e) {
        return ['ok'=>false, 'errors'=>[$e->field() => $e->getMessage
            ()]];
    }
}
```

(3) **Repository** — chi SQL (xem create() o muc tren). (4) **View** — chi hien thi, escape moi output bang e():

Listing 15: app/Views/leads/index.php — View chi hien thi + escape

```

<td><?= e($r['full_name']) ?></td>
<td><?= e($r['email']) ?></td>
<td><span class="badge <?= e($r['status']) ?>"><?= e($r['status'])
    ?></span></td>
```

Em da kiem chung bang **grep**: thu muc **Controllers/** va **Views/** **khong co** ->prepare / ->query / INSERT / DELETE; thu muc **Repositories/** va **Services/** **khong doc** \$\_POST/\$\_GET (chi xuat hien trong comment).

*[Anh chup man hinh] So sanh code Controller (khong SQL), Service, Repository (SQL), View (e()) (T17–T19).*

## 1.12 CRUD Module A va Module B (T20, T22)

Cả hai module có đầy đủ List / Create / Edit / Update / Delete; các thao tác thay đổi dữ liệu (**store**, **update**, **delete**) đều dùng **POST**. Module B (orders) có thêm **transaction** khi tạo phiếu và **JOIN** sang **leads** để hiển thị tên học viên.

**Quan ly Lead**  
Tong 25 lead

Xuat CSV Thung rác + Them lead

Tim ten, email, SDT... -- Tất cả trạng thái -- **Lọc** Xóa lọc

| ID | HO TEN         | EMAIL                   | SDT        | KHOA HOC          | TRANG THAI | HÀNH ĐỘNG |
|----|----------------|-------------------------|------------|-------------------|------------|-----------|
| 25 | Lam Van Phong  | lamvanphong25@gmail.com | 0910008952 | IELTS Foundation  | Lost       | Sua Xóa   |
| 20 | Ta Thi Anh     | tathianh20@gmail.com    | 0910007087 | Lap trình Web     | Lost       | Sua Xóa   |
| 15 | Cao Van Tuan   | caovantuan15@gmail.com  | 0910005222 | Thiet ke do hoa   | Lost       | Sua Xóa   |
| 10 | Ngo Thi Nga    | ngothinga10@gmail.com   | 0910003357 | IELTS Advanced    | Lost       | Sua Xóa   |
| 5  | Hoang Minh Duc | hoangminhduc5@gmail.com | 0910001492 | Data Science      | Lost       | Sua Xóa   |
| 24 | Kieu Thi En    | kieuthien24@gmail.com   | 0910008579 | Digital Marketing | Converted  | Sua Xóa   |
| 19 | Luong Van Yen  | luongvanyen19@gmail.com | 0910006714 | Lap trình Python  | Converted  | Sua Xóa   |
| 14 | Mai Thi Trang  | maithitran14@gmail.com  | 0910004849 | Tieng Nhat N5     | Converted  | Sua Xóa   |
| 9  | Do Quang Minh  | doquangminh9@gmail.com  | 0910002984 | IELTS Foundation  | Converted  | Sua Xóa   |
| 4  | Pham Thu Dung  | phamthudung4@gmail.com  | 0910001119 | Lap trình Web     | Converted  | Sua Xóa   |

1 2 3 Sau » Trang 1/3

Figure 5: Module A — danh sách Lead: toolbar tìm kiếm + lọc trạng thái, bảng có sort theo cột, phân trang (T20).

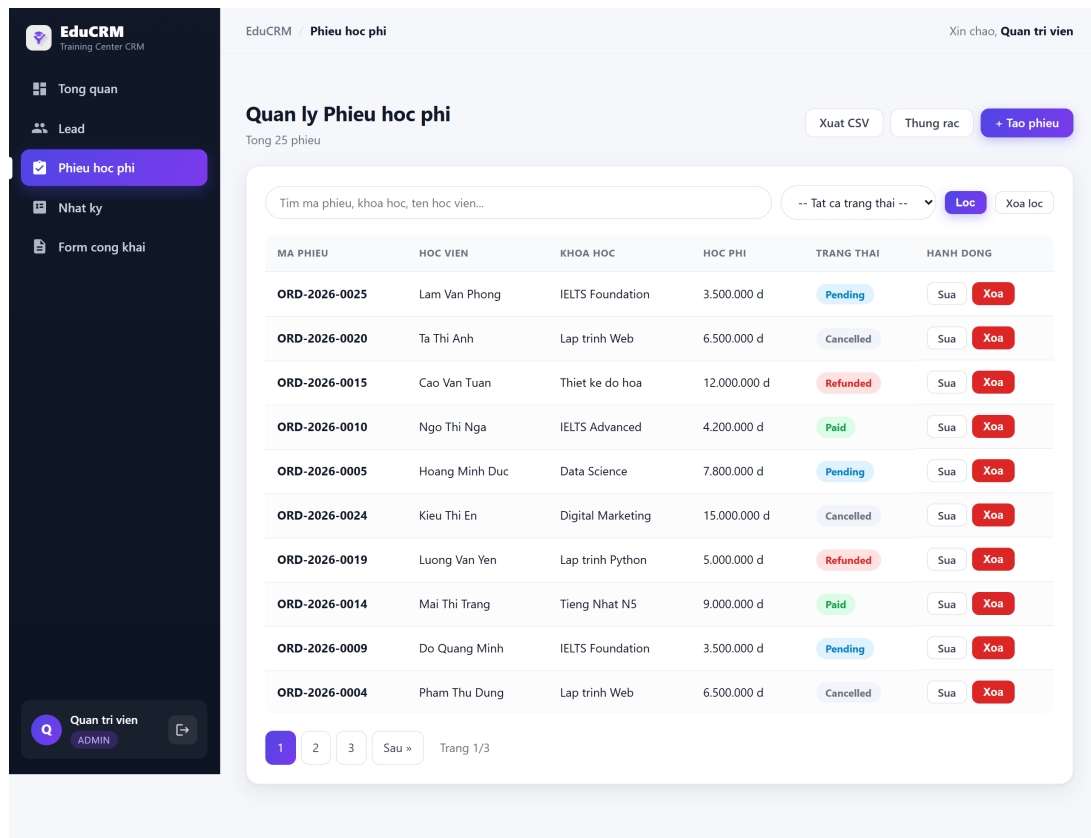


Figure 6: Module B — danh sach Phieu hoc phi: JOIN sang leads hien ten hoc vien, hien ma phieu / hoc phi / trang thai (T22).

### 1.13 Duplicate handling (T21, T23)

Khi trung UNIQUE (email lead hoac order\_code), Repository bat PDOException co SQLSTATE=23000 / errno 1062 va nem DuplicateRecordException gan ten field; Service chuyen thanh loi theo field, hien thi than thien **ma khong lo SQLSTATE**.

Listing 16: app/Core/DuplicateRecordException.php

```
class DuplicateRecordException extends RuntimeException {
    private string $field;
    public function __construct(string $field, string $message = '')
    {
        $this->field = $field;
        parent::__construct($message ?: "Gia tri truong $field da ton
            tai.");
    }
    public function field(): string { return $this->field; }
}
```

Ket qua test: tao lead trung email -> "Email nay da ton tai trong he thong."; tao order trung ma -> "Ma phieu nay da ton tai." (khong co SQLSTATE).

Figure 7: Duplicate handling: tạo lead với email đã tồn tại trong seed -> lỗi than phiền "Email này đã tồn tại trong hệ thống." gần đúng field, giữ old input, **không** lo SQL-STATE (T21, T23).

## 1.14 Search / Pagination / Sort an toan (T24, T25)

URL list dùng tham số: `q` (từ khóa), `status` (filter), `sort`, `direction`, `page`. `LeadService::list()` chuẩn hóa input an toan:

Listing 17: `app/Services/LeadService.php` — `list()` (pagination + whitelist)

```
if (!in_array($sort, self::SORTABLE, true)) $sort = 'created_at';
// whitelist cot
$dir = strtolower($dir) === 'asc' ? 'asc' : 'desc';
// whitelist direction
if ($status !== '' && !in_array($status, config('lead_statuses', []), true)) $status = '';

$total = $this->repo->countFiltered($q, $status);
$totalPages = max(1, (int) ceil($total / $perPage));
if ($page < 1) $page = 1; // clamp page am / 0 -> 1
if ($page > $totalPages) $page = $totalPages; // clamp page qua lon -> totalPages
$offset = ($page - 1) * $perPage;
```

Kết quả test (số 25 lead, 10/trang -> 3 trang):

- `q=Tran` -> trả 2 dòng dữ liệu từ khóa; `q=ZZZNOMATCH` -> "Không có lead nào khớp".
- `page=-5` -> Trang 1/3; `page=9999` -> Trang 3/3 (clamp dữ liệu).
- `sort=full_name&direction=asc` -> HTTP 200, sắp xếp đúng.

- **Sort nguy hiem** `sort=id DESC`; `DROP TABLE leads`; - `&direction=hacker` -> HTTP 200, hệ thống dùng sort mặc định `created_at DESC`, **bang leads vẫn còn nguyên** (không chạy SQL nguy hiểm).

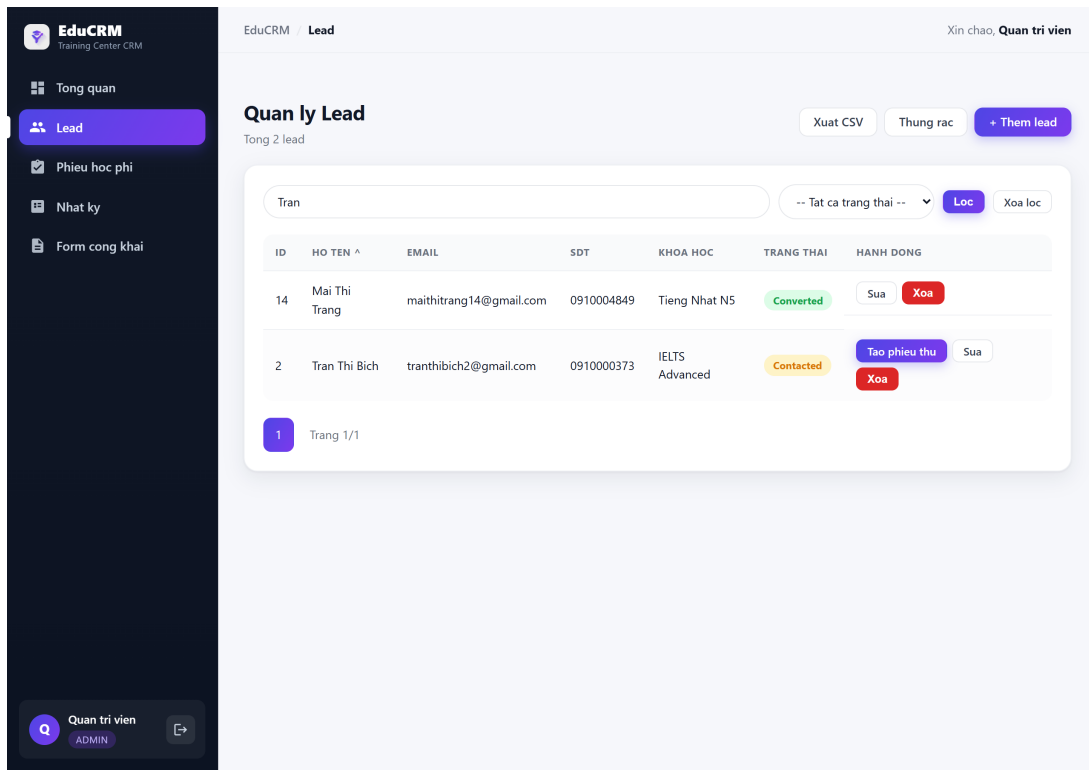


Figure 8: Search + sort an toan: `?q=Tran&sort=full_name&direction=asc` -> tra 2 dòng dữ liệu, sắp xếp tăng dần theo Họ tên, Trang 1/1 (T24, T25).

Figure 9: Form sua Lead (GET /leads/edit?id=1): du lieu cu duoc do san vao moi field, submit qua POST /leads/update (CRUD Update).

## 1.15 Health JSON, 404/405 va Safe error + logging (T26–T28)

GET /health tra JSON trang thai app/db:

Listing 18: GET /health (DB up) — output thuc te

```
{
  "status": "ok",
  "app": "EduCRM",
  "domain": "Training Center CRM",
  "database": "up",
  "php_version": "8.2.12",
  "timestamp": "2026-06-10T17:54:00+02:00"
}
```

**Production safe error:** config/app.php dat debug=false. Khi DB hong, Front Controller bat Throwable, ghi log chi tiet vao **storage/logs/app.log** va chi hien trang 500 an toan cho user — **khong lo** SQLSTATE / ten bang / duong dan / stack trace.

Listing 19: public/index.php — xu ly loi an toan

```
try {
    $router->dispatch($method, $path);
} catch (\Throwable $ex) {
    log_app('error', $ex->getMessage() . ' @ ' . $ex->getFile() . ':' .
        $ex->getLine());
    if ($debug) { /* dev: hien chi tiet */ }
    else { render_error(500, '500'); } // production: trang an toan
}
```

}

Test thuc te khi doi config/database.php sang database sai:

- GET /health -> HTTP **503**, JSON {status:degraded, database:down}, không có SQLSTATE.
- GET /leads -> HTTP **500**, trang "Đã có lỗi xảy ra"; grep SQLSTATE=0, path=0, ten bang=0.
- Log ghi: ERROR: SQLSTATE[HY000] [1049] Unknown database ... @ Database.php:50 (chỉ server-side thay).

404/405: GET /unknown-page -> 404 "Khong tim thay trang"; POST /health -> 405 kem header Allow: GET.

```

{
  "status": "ok",
  "app": "EduCRM",
  "domain": "Training Center CRM",
  "database": "up",
  "php_version": "8.2.12",
  "timestamp": "2026-06-14T10:01:32+02:00"
}

```

Figure 10: GET /health tra JSON trang thai app/db (database up) (T26).

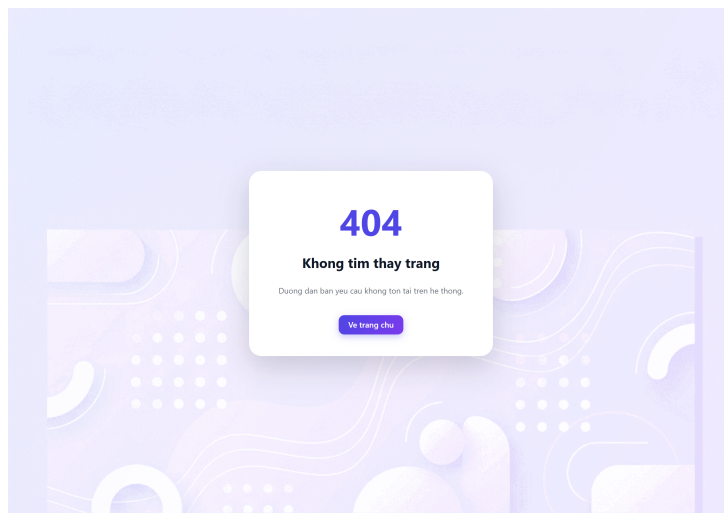


Figure 11: Route không tồn tại (**GET /nope**) -> trang 404 "Không tìm thấy trang" (T27). 405 + Allow và trang 500 an toàn được mô tả ở phần code/log ở trên (T28).

**1.16 EXPLAIN / index (T29)**

Em chày EXPLAIN cho query list/filter/sort. Ket qua thuc te:

Listing 20: EXPLAIN query list leads (filter status + sort theo created at)

| id | table | type  | possible_keys | key | len | ref |
|----|-------|-------|---------------|-----|-----|-----|
|    | rows  | Extra |               |     |     |     |

```

+----+-----+-----+-----+-----+-----+-----+
| 1 | leads | ref | idx_leads_status | idx_leads_status | 1 |
|   | const | 6   | Using index condition; |   |
|   |       |     |                   |   |
|   |       |     | Using where; Using filesort |
+----+-----+-----+-----+-----+-----+

```

Nhan xet: cot key = idx\_leads\_status (**khong NULL**) -> MySQL dung index de loc status thay vi quet toan bang. Using filesort xuat hien do sort theo created\_at khac cot loc; voi bang nho chap nhan duoc, bang lon co the them composite index (status, created\_at) de bo filesort.

Listing 21: EXPLAIN lookup lead theo email (UNIQUE)

```

+----+-----+-----+-----+-----+-----+-----+
| id | table | type | possible_keys | key | len | ref |
| rows | Extra |
+----+-----+-----+-----+-----+-----+
| 1 | leads | const | uq_leads_email | uq_leads_email | 602 | const |
| 1 |      |      |                |                |    |      |
+----+-----+-----+-----+-----+-----+

```

Nhan xet: type=const, key=uq\_leads\_email -> tra cuu trung email gan nhu  $O(1)$  qua unique index — rat hieu qua cho buoc chong trung khi tao lead.

Listing 22: EXPLAIN orders JOIN leads (filter status paid + sort)

```

+----+-----+-----+-----+-----+-----+-----+
| id | table | type | possible_keys | key |
| rows | Extra |
+----+-----+-----+-----+-----+-----+
| 1 | o      | ref  | idx_orders_status,idx_orders_lead_id |
| idx_orders_status | 6 | Using index ... |
| 1 | l      | eq_ref | PRIMARY |
| PRIMARY | 1 | |
+----+-----+-----+-----+-----+-----+

```

Nhan xet: bang o dung idx\_orders\_status (ref); JOIN sang leads qua khoa chinh (eq\_ref, 1 row) — khong co full table scan.

*[Anh chup man hinh] Ket qua EXPLAIN trong MySQL CLI (T29).*

## 1.17 GitHub / README (T30)

Source duoc quan ly bang Git, day len GitHub kem README day du (cach tao DB, chay server, tai khoan demo, danh sach route, cau truc folder, luu y debug/prod).

- **Repository:** <https://github.com/lphhien112-gif/PHP->
- **Thu muc:** PHP-Lab06/EduCRM/

## 1.18 Bang route day du

| Method       | URL                  | Controller@Action                  |
|--------------|----------------------|------------------------------------|
| GET          | /                    | (redirect dashboard / public form) |
| GET          | /login               | AuthController@loginForm           |
| POST         | /login               | AuthController@handleLogin         |
| POST         | /logout              | AuthController@logout              |
| GET          | /dashboard           | DashboardController@index          |
| GET          | /public-leads/create | PublicLeadController@create        |
| POST         | /public-leads        | PublicLeadController@store         |
| GET          | /leads               | LeadController@index               |
| GET          | /leads/create        | LeadController@create              |
| POST         | /leads/store         | LeadController@store               |
| GET          | /leads/edit?id=      | LeadController@edit                |
| POST         | /leads/update        | LeadController@update              |
| POST         | /leads/delete        | LeadController@delete (admin)      |
| GET          | /orders              | OrderController@index              |
| GET          | /orders/create       | OrderController@create             |
| POST         | /orders/store        | OrderController@store              |
| GET          | /orders/edit?id=     | OrderController@edit               |
| POST         | /orders/update       | OrderController@update             |
| POST         | /orders/delete       | OrderController@delete (admin)     |
| GET          | /health              | HealthController@index             |
| ANY          | (khong ton tai)      | Router -> 404                      |
| (sai method) | (route ton tai)      | Router -> 405 + Allow              |

## 2 Checklist task T01–T30 va Test Result TC01–TC25

### 2.1 Checklist task nho T01–T30

| Ma  | Task                                                                                                                     | Trang thai |
|-----|--------------------------------------------------------------------------------------------------------------------------|------------|
| T01 | Setup moi truong (PHP 8.2.12, MySQL, curl, Git)                                                                          | ✓          |
| T02 | Tao project dung cau truc (public, config, app/Core, Controllers, Services, Repositories, Views, database, storage/logs) | ✓          |
| T03 | Front Controller + Router (entry point duy nhat, 404/405)                                                                | ✓          |
| T04 | Session cookie setup (HttpOnly, SameSite, Secure) truoc session_start                                                    | ✓          |
| T05 | Helpers: e, redirect, render, partial, flash/get_flash, old, require_login                                               | ✓          |
| T06 | Layout/Partial dung chung (nav, flash), view con khong lap header/footer                                                 | ✓          |
| T07 | Form cong khai secure: trim, validate server-side, old input                                                             | ✓          |
| T08 | PRG sau submit hop le (F5 khong tao trung)                                                                               | ✓          |
| T09 | Honeypot + rate limit theo session                                                                                       | ✓          |
| T10 | Login sai bao loi / dung redirect dashboard                                                                              | ✓          |
| T11 | session_regenerate_id(true) sau login                                                                                    | ✓          |
| T12 | Timeout + logout sach (xoa session data, cookie, destroy)                                                                | ✓          |
| T13 | Schema: users + 2 bang nghiep vu, PK, UNIQUE, INDEX, timestamp                                                           | ✓          |
| T14 | Seed: tai khoan demo + >= 20 dong/module (25 + 25)                                                                       | ✓          |
| T15 | PDO chuan (utf8mb4, EXCEPTION, FETCH_ASSOC, EMULATE=false)                                                               | ✓          |
| T16 | Repository prepared statement (khong noi input vao SQL)                                                                  | ✓          |
| T17 | Service layer (validate, pagination, duplicate)                                                                          | ✓          |
| T18 | Controller mong (chi request -> service -> render/redirect)                                                              | ✓          |
| T19 | View an toan (escape e() moi output)                                                                                     | ✓          |
| T20 | Module A (leads) CRUD day du, POST cho store/update/delete                                                               | ✓          |
| T21 | Module A duplicate (email) bao loi than thien, khong lo SQLSTATE                                                         | ✓          |
| T22 | Module B (orders) CRUD day du theo rule riêng                                                                            | ✓          |
| T23 | Module B duplicate (order_code) bao loi dung field                                                                       | ✓          |
| T24 | Search/pagination/sort (q/page/sort/direction); xu ly page xau                                                           | ✓          |
| T25 | Sort nguy hiem -> sort mac dinh, khong loi SQL                                                                           | ✓          |
| T26 | Health JSON (app/database status)                                                                                        | ✓          |
| T27 | 404 (/unknown) va 405 (POST /health)                                                                                     | ✓          |
| T28 | Production safe error (debug=false khong lo SQL-STATE/path)                                                              | ✓          |
| T29 | EXPLAIN query list/filter/sort + nhan xet index                                                                          | ✓          |

| Ma  | Task                                           | Trang thai |
|-----|------------------------------------------------|------------|
| T30 | GitHub + README (DB, route, demo account, anh) | ✓          |

## 2.2 Bang Test Result TC01–TC25

Tat ca test duoc chay that bang curl tren server 127.0.0.1:8106 va kiem chung trong database. Cot *Ket qua thuc te* ghi gia tri quan sat duoc.

| Ma   | Cach test                     | Ket qua mong doi                             | Ket qua thuc te                                                   | P/F |
|------|-------------------------------|----------------------------------------------|-------------------------------------------------------------------|-----|
| TC01 | GET /login                    | Form login hien, khong can session           | HTTP 200, form login hien thi                                     | ✓   |
| TC02 | Login sai mat khau            | Loi than thien, khong tao session            | HTTP 302 -> /login, log "Login failed", khong co session user     | ✓   |
| TC03 | Login dung                    | Redirect /dashboard, co session, flash 1 lan | HTTP 302 -> /dashboard, dashboard 200                             | ✓   |
| TC04 | GET /dashboard chua login     | Redirect /login                              | HTTP 302 -> /login                                                | ✓   |
| TC05 | Logout                        | Destroy session, khong vao dashboard         | HTTP 302 -> /login; sau do /dashboard -> 302 /login               | ✓   |
| TC06 | Timeout phien                 | Khong hoat dong qua han -> login lai         | require_login() so sanh last_activity > 1800s -> redirect /login  | ✓   |
| TC07 | Public form thieu field       | Loi canh field, giu old input                | HTTP 302, 4 field-error, old input "bademail" giu lai             | ✓   |
| TC08 | Public form honeypot          | Field an co data -> tu choi                  | HTTP 302; leads count truoc=25 sau=25 (khong insert)              | ✓   |
| TC09 | Public form hop le            | Redirect PRG, flash, F5 khong trung          | HTTP 302 (PRG); DB row status=new, source=website                 | ✓   |
| TC10 | Module A create thieu field   | Khong luu, loi dung field                    | HTTP 302, 4 field-error, khong insert                             | ✓   |
| TC11 | Module A create hop le        | Redirect list, flash, DB co dong moi         | HTTP 302 -> /leads, row moi                                       | ✓   |
| TC12 | Module A duplicate email      | Loi than thien, khong lo SQLSTATE            | HTTP 302 -> /leads/create, "Email nay da ton tai trong he thong." | ✓   |
| TC13 | Module A edit/update          | Form co data cu, update redirect list        | GET edit 200 co email cu; POST update 302, DB cap nhat            | ✓   |
| TC14 | Module A delete bang POST     | Xoa thanh cong, GET delete khong duoc        | GET /leads/delete -> 405; POST delete -> 302, row=0               | ✓   |
| TC15 | Module B create hop le        | Redirect list, flash                         | HTTP 302 -> /orders, row moi                                      | ✓   |
| TC16 | Module B duplicate order_code | Loi dung field                               | HTTP 302 -> /orders/create, "Ma phieu nay da ton tai."            | ✓   |
| TC17 | Search /leads?q=Tran          | Chi hien data khop                           | q=Tran -> 2 dong; q=ZZZ -> "Khong co lead nao khop"               | ✓   |
| TC18 | Page am / qua lon             | Chuan hoa ve 1 hoac totalPages               | page=5 -> Trang 1/3; page=9999 -> Trang 3/3                       | ✓   |
| TC19 | Sort hop le                   | Sort dung cot/direction                      | sort=full_name&direction=asc -> 200, sap dung                     | ✓   |
| TC20 | Sort nguy hiem                | Khong chay SQL nguy hiem, sort mac dinh      | sort="id DESC; DROP TABLE..." -> 200, bang con nguy               | ✓   |
| TC21 | GET /health                   | JSON status app/db                           | HTTP 200, status:ok, database:up                                  | ✓   |

| Ma   | Cach test           | Ket qua mong doi                      | Ket qua thuc te                                                     | P/F |
|------|---------------------|---------------------------------------|---------------------------------------------------------------------|-----|
| TC22 | POST /health        | 405 Method Not Allowed                | HTTP 405, header "Allow: GET"                                       | ✓   |
| TC23 | GET /unknown        | 404 Not Found                         | HTTP 404, "Khong tim thay trang"                                    | ✓   |
| TC24 | DB loi (production) | Khong lo SQL-STATE/path; log/safe msg | /health 503 down; /leads 500 an toan; SQL-STATE=0; log ghi chi tiet | ✓   |
| TC25 | EXPLAIN query list  | Query co index khi filter/sort        | key=idx_leads_status (khong NULL); email -> uq_leads_email          | ✓   |

**Tong ket: 25/25 test case PASS.**

## 3 Cau 2: Problem Solving

### 3.1 Front Controller & Router

Trong EduCRM, **mọi request đều đi qua public/index.php**. Router map METHOD + PATH -> Controller@Action bằng cách lưu danh sách route và số khớp tuần tự (ví dụ POST /leads/store -> LeadController@store). Nếu mỗi file PHP xử lý một URL riêng, khi thêm **auth** sẽ phải thêm `require_login()` vào từng file; thêm **middleware** (logging, CSRF) phải sửa hàng chục chỗ; **404/405** không đồng nhất. Với Front Controller, em chỉ cần thêm một dòng trước `dispatch()` là áp dụng cho toàn bộ route, và Router phân biệt 404/405 tập trung một nơi.

### 3.2 Secure form

Form công khai /public-leads kiểm tra server-side trong `LeadService::validate()`: `trim` + `required`, email bằng `filter_var(...FILTER_VALIDATE_EMAIL)`, phone bằng regex `/^\d{9,10}$/, course` phải thuộc whitelist khoa học, giới hạn độ dài. Không thể chỉ dựa vào `required/type=email` của HTML vì attacker có thể bỏ qua trình duyệt (dùng curl/Postman) gửi thang POST, hoặc sửa DOM; validate HTML chỉ là trải nghiệm người dùng, **không phải biện pháp bảo mật**.

### 3.3 PRG Pattern

Sau POST thành công, EduCRM **redirect (302)**: `/leads/store -> /leads, /public-leads -> /public-leads/create`. Nếu render kết quả trực tiếp trên request POST, khi user bấm **F5** trình duyệt sẽ gửi lại POST -> **tao ban ghi trung** (ví dụ tạo 2 lead/2 order giống nhau) hoặc kích hoạt lại thành toán. PRG đảm bảo F5 chỉ tải lại trang GET vào hai.

### 3.4 Anti-spam cơ bản

**Honeypot**: field ẩn website (CSS đưa ra ngoài màn hình). Người thật không điền, **bot** thường điền hết field -> bị chặn (giả vờ thành công để bot không biết). **Rate limit theo session**: tôi đã 5 submit / 300 giây, chống gửi liên tục. Giới hạn: honeypot vô hiệu với bot thông minh; rate limit theo session để bị vượt bằng cách xóa cookie / đổi session. Khi cần mạnh hơn nên nâng cấp **CSRF token** (đã có trong project cho form nội bộ), **reCAPTCHA**, và **rate limit theo IP** ở tầng web server.

### 3.5 Session/login flow

Flow trong project: `AuthService::attempt()` validate input -> `password_verify` với hash bcrypt -> `AuthService::login()` gọi `session_regenerate_id(true)` -> lưu user/role/login\_id -> `flash` -> redirect /dashboard. Nếu không regenerate id sau login, kẻ tấn công đã biết trước session id (do gán cho nạn nhân từ lúc chưa đăng nhập) có thể **session fixation**: dùng lại chính session id đó để chiếm phiên sau khi nạn nhân đăng nhập.

### 3.6 Logout, timeout va cookie flags

Logout xoa `$_SESSION = []`, `setcookie` cookie session ve qua khu (xoa cookie), va `session_destroy()`. Timeout: `require_login()` so sanh `time() - last_activity > 1800` -> xoa session + redirect /login. **HttpOnly** ngan JavaScript doc cookie (giam danh cap session qua XSS); **SameSite=Lax** ngan gui cookie trong request cross-site (giam CSRF); **Secure** (bat khi HTTPS) ngan cookie di qua HTTP khong ma hoa.

### 3.7 Remember me

EduCRM khong luu password vao cookie. **Khong duoc** luu password vi cookie nam o may client, de bi doc/danh cap (XSS, may dung chung) -> lo mat khau truc tiep. Neu lam that, em se sinh mot **token ngau nhien** (selector + validator), luu hash cua validator trong DB kem `user_id` va `expires_at`; cookie chi chua token; khi quay lai, so hash token, hop le thi tao phien moi va **xoay token** (rotation). Token co the thu hoi va het han, an toan hon luu credential.

### 3.8 Database schema

Em thiet ke `users` (nguoi dang nhap), `leads` (lead tu van) va `orders` (phieu hoc phi) vi do la 3 thuc the cot loi cua CRM trung tam dao tao. **Primary key**: id moi bang. **Foreign key**: `orders.lead_id` -> `leads.id` (ON DELETE CASCADE — xoa lead thi phieu lien quan cung xoa). **Unique**: `users.username`, `leads.email`, `orders.order_code`. **Index**: `idx_leads_status`, `idx_leads_course`, `idx_orders_status`, `idx_orders_lead_id`, `*_created_at` (ho tro filter/sort). **Timestamp**: `created_at`, `updated_at` (auto cap nhat).

### 3.9 Prepared statements

Chon 1 INSERT va 1 SELECT trong `LeadRepository`:

- INSERT: `INSERT INTO leads (...) VALUES (:full_name, :email, ...)` — cau lenh SQL co dinh, du lieu nguoi dung truyen qua mang `execute([':email' => $data['email'], ...])`.
- SELECT: `... WHERE (full_name LIKE :q_name OR email LIKE :q_email ...)` — tu khoa tim kiem bind qua placeholder `:q_name`.

SQL command va user input duoc **tach hoan toan**: voi `EMULATE_PREPARES=false`, driver gui cau lenh va tham so rieng den MySQL; input luon duoc coi la **du lieu**, khong bao gio la **cu phap SQL** -> chong SQL Injection triet de (vi du nhap ' OR 1=1 - chi thanh chuoi tim kiem vo hai).

### 3.10 Unique constraint & duplicate handling

Chi kiem tra trung bang PHP (SELECT truoc roi INSERT) la chua du vi co **race condition**: hai request gan nhu dong thoi cung SELECT thay "chua ton tai" roi cung INSERT -> tao 2 ban ghi trung. **UNIQUE constraint** o DB la **rang buoc nguyen tu o tang luu tru**: chi mot INSERT thanh cong, cai con lai bi tu choi (errno 1062), va EduCRM bat thanh `DuplicateRecordException` -> thong bao than thien. Day la "nguồn sự thật" cuối cùng chong trung.

### 3.11 Search/pagination/sort safe

URL list dung `q`, `status`, `sort`, `direction`, `page`. Xu ly: `page` ep (int), `< 1 -> 1`, `> totalPages -> totalPages`; `sort` phai thuoc whitelist `SORTABLE` (neu khong -> `created_at`); `direction` chi nhan `asc/desc`; `status` phai thuoc whitelist. Sort nguy hiem (`id DESC`; `DROP TABLE...`) khong nam trong whitelist nen bi thay bang mac dinh -> **khong bao gio ghep chuoi nguy hiem vao ORDER BY**. Da test: bang leads van con nguyen sau khi thu.

### 3.12 Index & EXPLAIN

Query `SELECT ... FROM leads WHERE status='new' ORDER BY created_at DESC LIMIT 10`; `EXPLAIN` cho `key=idx_leads_status`, `type=ref` -> co dung index loc status (khong full scan). Neu `key=NULL` tren bang lon (vi du chua co index hoac dieu kien khong sargable), em se: them **index** cho cot loc, tao **composite index** (`status`, `created_at`) de vua loc vua sort (bo `Using filesort`), va tranh ham bao quanh cot trong `WHERE`.

### 3.13 MVC dung trach nhien

Trong EduCRM: **Controller** doc request, goi Service, render/redirect (vi du `LeadController::store()` chi goi `$this->leads->create($_POST)` roi redirect — **khong co dong SQL nao**). **Service** giu rule (validate, pagination, duplicate). **Repository** chua toan bo SQL prepared. **View** chi hien thi va escape: vi du `leads/index.php` chi co `<?= e($r['email']) ?>`, **khong he query DB**. Emkiem chung bang grep: `Controllers/Views` khong co `->prepare/->query`; `Repositories/Services` khong doc `$_POST/$_GET`.

### 3.14 Layout/Partial & XSS

Dung layout/partial (`layouts/main.php`, `partials/nav.php`, `partials/flash.php`) de tranh lap header/menu/footer o nhieu view — sua mot noi ap dung toan bo, giam loi va de bao tri. Du lieu tu DB/user duoc escape bang `e()` (`htmlspecialchars` voi `ENT_QUOTES`) **ngay tai View** truoc khi in ra HTML, chong XSS (vi du ten lead chua `<script>` se thanh text vo hai).

### 3.15 Dev/prod error message

Production khong nen hien `$e->getMessage()`, `SQLSTATE` hay stack trace vi chung lo **cau truc he thong** (ten bang, cot, duong dan file, phien ban) — giup attacker do tham. EduCRM: khi loi, Front Controller `log_app('error', ...)` ghi chi tiet vao `storage/logs/app.log` (server-side), con user chi thay trang 500 "Da co loi xay ra" (khi `debug=false`). Da kiem chung: grep `SQLSTATE` tren HTML tra ve user = 0.

### 3.16 404 vs 405

Vi du trong project: `GET /khong-ton-tai -> 404` (Router khong tim thay path nao). `POST /health -> 405` (path `/health` co ton tai nhung chi cho `GET`, kem header `Allow: GET`). Can phan biet vi 404 bao "tai nguyen khong ton tai" (client kiem tra lai URL), con 405 bao "sai phuong thuc" (client doi method dung) — giup client/crawler hanh xu dung va debug nhanh.

### 3.17 Delete bang POST

Delete/update không nên dùng GET vì GET phải **idempotent** và **an toàn** (không đổi trạng thái). Nếu delete qua GET: crawler/Googlebot đi theo link có thể **xóa dữ liệu**; trình duyệt prefetch hoặc tính năng preview link có thể kích hoạt; user bấm nhầm hoặc mô lại từ lịch sử cũng xóa nhầm. EduCRM dùng POST `/leads/delete` + CSRF token + xác nhận, và GET vào `/leads/delete` trả **405**.

### 3.18 Hướng phát triển tiếp

Với bài toán trung tâm đào tạo, em ưu tiên: **(1) CSRF** (đã có — bảo vệ mọi form POST); **(2) Role permission** (đã có ở mức cơ bản — admin xóa, staff không; mô rõ ràng thêm quyền chi tiết); **(3) Logging/audit trail** (ai sửa lead/order nào, khi nào — quan trọng với dữ liệu khách hàng và tiền học phí); **(4) Transaction** (đã dùng khi tạo order; mô rõ ràng khi thêm `order_items`/payment); **(5) Soft delete** (`deleted_at` để khôi phục dữ liệu khách hàng); sau đó mới đến **tests**, **API** và **Docker**. Lý do: dữ liệu lead/order gần với tiền và khách hàng nên **toàn vẹn và truy vết** được ưu tiên hàng đầu.

## 4 Tinh nang mo rong nang cao va giao dien hien dai

Sau khi hoan thanh yeu cau bat buoc, em phat trien them cac tinh nang nang cao (F1–F5) theo huong mot CRM thuc te, kem mot dot **redesign giao dien** theo phong cach **admin sidebar hien dai**. Tat ca deu duoc **kiem thu live** tren database that (MariaDB) bang trinh duyyet va curl; bang ket qua o cuoi muc.

### 4.1 F1 — Chuyen Lead thanh Phieu thu (transaction)

Tu mot lead trang thai `qualified/contacted`, nut “Tao phieu thu” mo form order da dien san (ma phieu goi y, khoa hoc, hoc vien). Khi luu, trong **mot transaction**: `INSERT order + UPDATE lead sang converted + ghi audit`; neu trung `order_code` thi `rollBack` ca hai. Guard nguyen tu o muc SQL: `UPDATE ... WHERE id=:id AND status NOT IN ('converted', 'lost')` de chong double-submit.

The screenshot shows the 'Tao phieu thu tu Lead' form in the EduCRM interface. The form is pre-filled with the following data:

- Hoc vien:** Le Hoang Cuong
- Email:** lehoangcuong3@gmail.com
- SDT:** 0910000746
- Trang thai:** Qualified
- Ma phieu \*:** ORD-2026-7969
- Khoa hoc \*:** Lap trinh Python
- Hoc phi (VND) \*:** (empty)
- Trang thai phieu:** pending
- Ngay thanh toan:** mm/dd/yyyy
- Ghi chu:** (empty text area)

At the bottom of the form, there are two buttons: 'Tao phieu & chuyen doi' (highlighted in purple) and 'Huy'.

Figure 12: F1: form chuyen lead sang phieu thu (prefilled). Da verify live: lead 3 -> converted, order ORD-2026-9678 tao moi (orders 25->26).

### 4.2 F2 — Soft delete + Thung rac (Restore)

Xoa = danh dau `deleted_at` (khong DROP); moi truy van doc deu loc `deleted_at IS NULL`. Trang `/leads/trash` (chi admin) cho **khoi phuc** hoac **xoa vinh vien**. Em cung sua mot bug do dot review phat hien: `UNIQUE(email)` cu van chan ban ghi da xoa mem, nen em chuyen sang `cot sinh email_active = IF(deleted_at IS NULL, email, NULL) + UNIQUE(email_active)` (M1) — ban ghi trong thung rac khong con chiem unique.

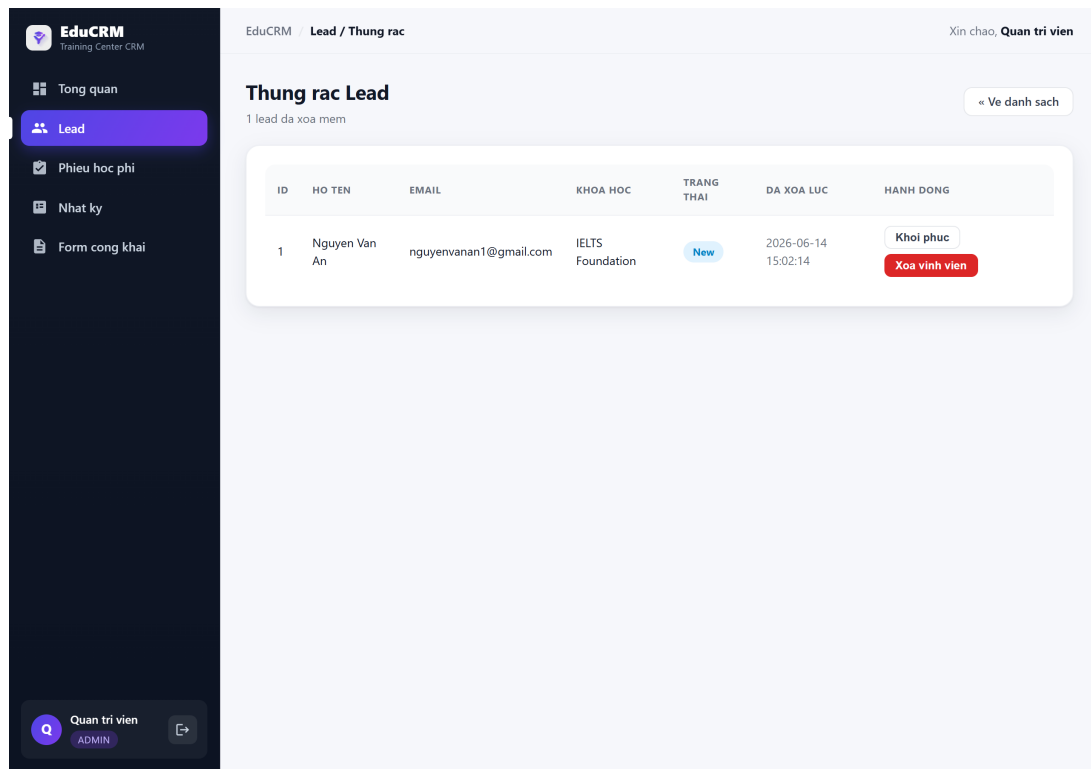


Figure 13: F2: thung rac liet ke ban ghi da xoa mem, co Khoi phuc / Xoa vĩnh viễn (chi admin). Da verify: xoa -> trash -> restore.

### 4.3 F3 — Audit log (nhat ky hoat dong)

Bang `activity_logs` ghi **ai lam gi luc nao** (create/update/delete/restore/convert/login/logout/login\_failed), không lưu PII. Trang `/audit` chỉ admin (staff bị redirect về dashboard — đã verify server-side).

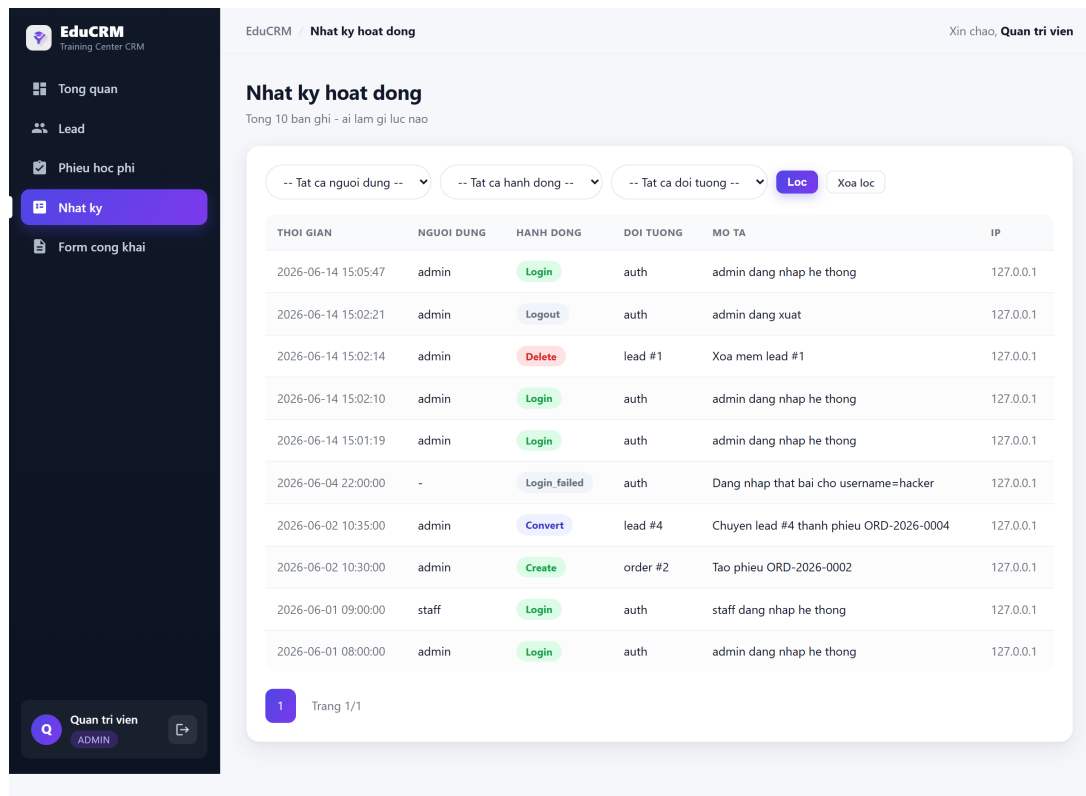


Figure 14: F3: nhật ký hoạt động, lọc theo user/action/entity, phân trang; chỉ admin truy cập.

#### 4.4 F4 — Export CSV an toan

/leads/export va /orders/export stream CSV theo dung filter hien tai, co **Content-Disposition: attachment, UTF-8 BOM** (mo dung trong Excel), va chong **CSV injection** (them dau nhay don truoc o bat dau bang = + - @). Da verify: **Content-Type: text/csv**, BOM EF BB BF, 26 dong dung filter.

#### 4.5 F5 — Dashboard analytics

Dashboard bo sung 4 khoi truc quan ve bang CSS/SVG thuan (khong dung thu vien JS): **lead theo 14 ngay**, **pheu chuyen doi** (new -> contacted -> qualified -> converted), **doanh thu 6 thang** (chi tinh paid), **Top 5 khoa hoc**.

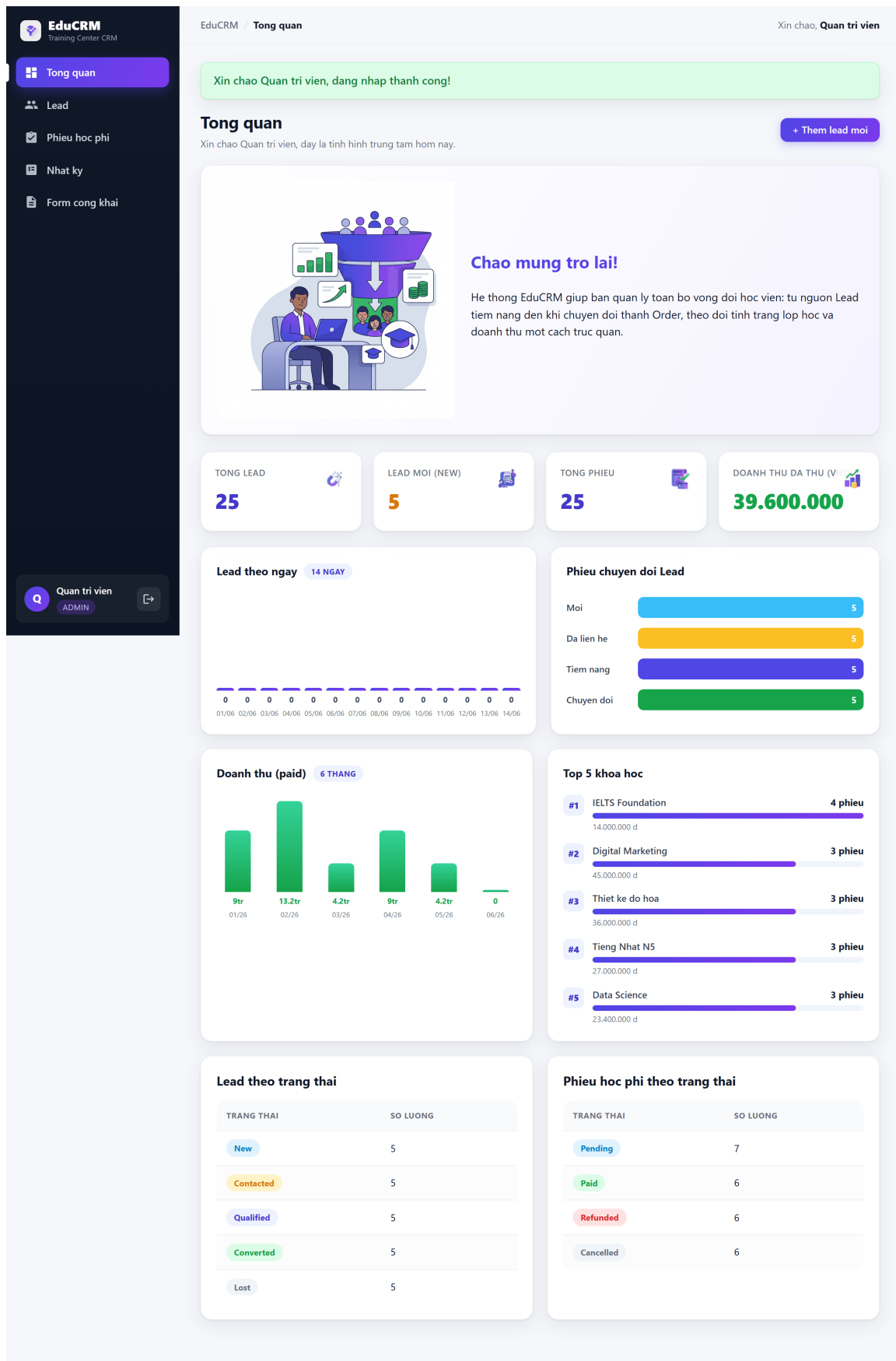


Figure 15: F5 + giao dien moi: shell sidebar admin (logo, nav co icon, user/role/logout), va 4 khoi analytics voi so lieu that.

## 4.6 Giao dien hien dai (redesign)

Em chuyen tu thanh top-bar sang **sidebar admin co dinh** (logo, nav co icon SVG, trang thai active, user/role/logout o day), top bar mong + breadcrumb, the bo goc 16px + do bong nhieu lop, status pill, bang sticky header, flash toast, va **responsive** (sidebar thu thanh off-canvas drawer o man hinh nho). Toan bo giu dung kien truc MVC va khong pha chuc nang dang chay.

## 4.7 Tinh nang F6–F11 (CRM nang cao)

Em phat trien tiep mot loat tinh nang nang cao, deukiem thu live bang curl va trinh duyet:

- **F6 — Login hardening:** khoa dang nhap sau nhieu lan sai (bang `login_attempts`); **remember-me** bang token — luu **hash** token trong `remember_tokens`, cookie selector: token (HttpOnly/SameSite), **rotate** moi lan dung, **revoke** khi logout. Tuyet doi khong luu mat khau trong cookie.
- **F7 — JSON API + Bearer token:** GET `/api/leads`, `/api/orders`, `/api/stats` chi doc, xac thuc qua header `Authorization: Bearer <token>` (so voi bang `api_tokens`); token sai/thieu tra **401**.
- **F10 — Hoa don in duoc:** GET `/orders/invoice?id=` tra trang hoa don sach (print CSS), nut “In hoa don” goi `window.print()`.
- **F11 — Role manager:** `users.role` mo rong thanh `admin/manager/` `staff`, phan quyen **enforce server-side** (khong chi an nut tren giao dien).
- **F8 — Loc khoang ngay** (`created_from/created_to`) va **F9 — Bulk actions** (POST `id[]`: xoa mem / doi trang thai hang loat) cho danh sach.

Listing 23: GET `/api/stats` voi Bearer token hop le — tra JSON 200

```
{
  "data": {
    "leads": {
      "total": 25,
      "by_status": { "new": 5, "contacted": 5, "qualified": 4, "
        converted": 6, "lost": 5 }
    }
    // ... orders, revenue ...
  }
}
```

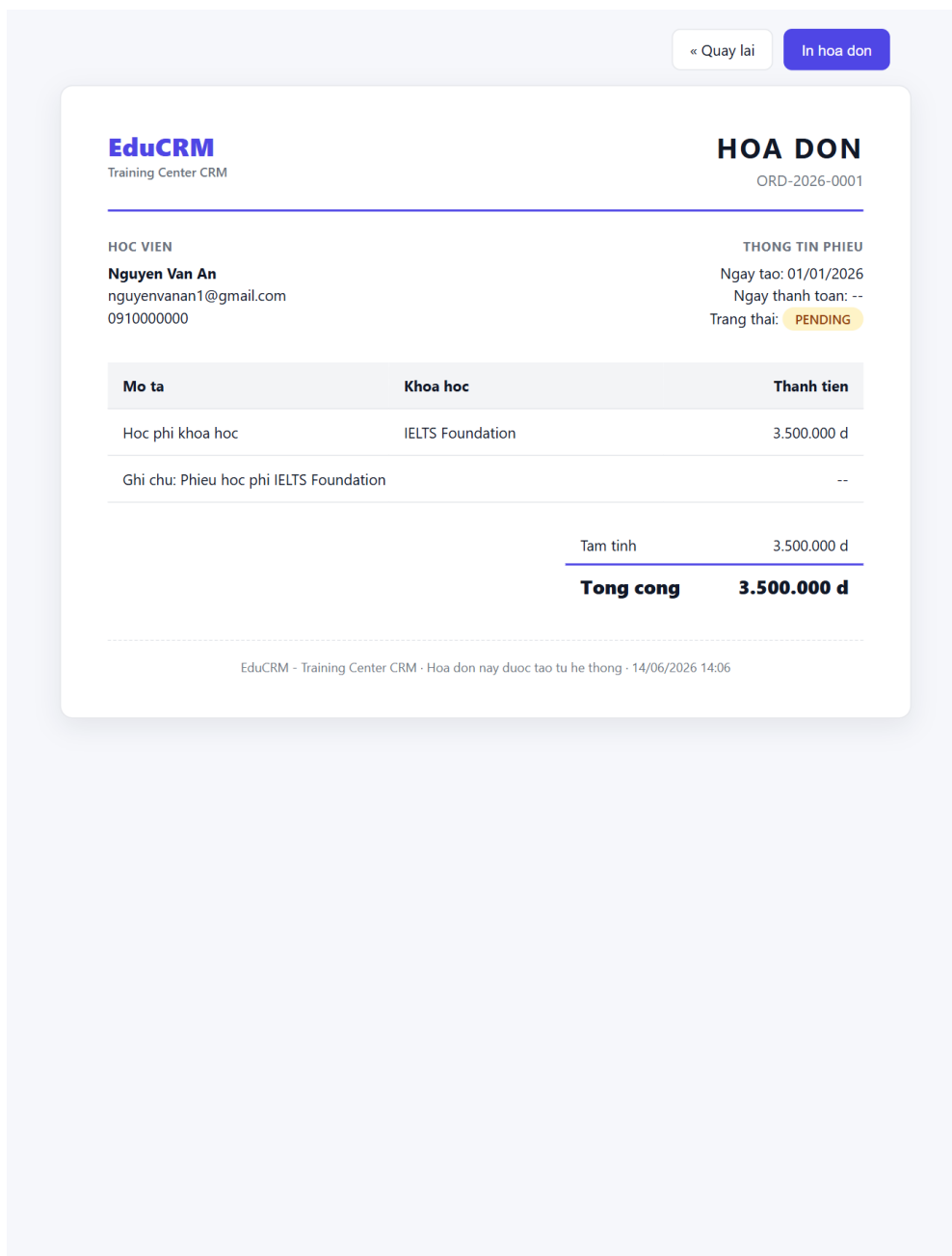


Figure 16: F10: hoa don in duoc (GET /orders/invoice?id=1) — print CSS, nut “In hoa don”, tong tien.

## 4.8 Bang kiem thu tinh nang mo rong (verify live)

| Ma               | Cach test                                                  | Ket qua thuc te                                                                | P/F |
|------------------|------------------------------------------------------------|--------------------------------------------------------------------------------|-----|
| F1 convert       | Convert lead qualified (id=3), dien hoc phi, submit        | Order ORD-2026-9678 tao moi; lead 3 -> converted; orders 25->26; audit convert | ✓   |
| F1 guard         | Convert lai lead da converted                              | Bi chan, khong tao order thu hai                                               | ✓   |
| F2 delete        | Admin xoa mem lead 1                                       | Mat khoi list, vao /trash; <b>deleted_at</b> set; audit delete                 | ✓   |
| F2 restore       | Khoi phuc lead 1                                           | <b>deleted_at</b> =NULL, ve list; audit restore                                | ✓   |
| M1 unique        | Lead da xoa mem                                            | <b>email_active</b> =NULL -> khong chan tao moi cung email                     | ✓   |
| M2 login<br>CSRF | POST /login thieu <b>_csrf</b>                             | 302 ve /login, khong dang nhap duoc                                            | ✓   |
| F3 audit         | Mo /audit                                                  | 10 dong; staff -> 302 /dashboard (admin-only)                                  | ✓   |
| F4 CSV           | GET /leads/export (admin)                                  | text/csv + attachment + BOM + 26 dong                                          | ✓   |
| F5 analytics     | Mo /dashboard                                              | 4 bieu do so that                                                              | ✓   |
| Role             | Staff POST /leads/force-delete                             | Bi chan, lead 2 con nguyen                                                     | ✓   |
| F7 API           | GET /api/leads + Bearer hop le / sai                       | 200 JSON / 401 (token sai)                                                     | ✓   |
| F10 invoice      | GET /orders/invoice?id=1 (admin)                           | 200 HTML hoa don ORD-2026-0001                                                 | ✓   |
| F11 role         | users co admin/manager/staff; quyen enforce server-side    | ✓                                                                              |     |
| F6 remember      | Token <b>hash</b> trong remember_tokens, revoke khi logout | ✓                                                                              |     |

## 4.9 Problem Solving (tinh nang moi)

- **Vi sao F1 phai dung transaction?** Tao order va doi lead sang converted phai toan ven: neu order trung ma bi loi ma lead da bi danh dau converted thi du lieu sai lech. rollBack dam bao “ca hai cung thanh cong hoac cung khong”.
- **Soft delete va unique index?** Soft delete giu du lieu phuc hoi duoc, nhung phai xu ly rang buoc unique: cot sinh **email\_active** cho phep tai su dung email cua ban ghi da o thung rac ma khong vi pham UNIQUE.
- **Vi sao can audit log?** De truy vet trach nhien (ai doi/xoa gi) — thiet yeu cho he thong gan voi tien; chi admin xem, khong log mat khau/PII.
- **CSV injection?** O bat dau bang = + - @ co the bi Excel hieu la cong thuc; em them dau nhay don de vo hieu hoa.

## 5 Ket luan

Qua Lab06 Final, em da xay dung hoan chinh **EduCRM — Training Center CRM**, mot Secure MVC Mini CRM chay duoc end-to-end voi database that,kiem thu that bang curl. Em nam vung:

- Kien truc **Front Controller + Router** voi 404/405 chuan HTTP.
- **Session/login an toan**: cookie flags, `session_regenerate_id(true)`, timeout, logout sach.
- **Form secure** + PRG + honeypot + rate limit.
- **PDO chuan** + prepared statement + whitelist sort -> chong SQL Injection.
- **MVC dung trach nhien**: Controller mong, Service rule, Repository SQL, View escape.
- **Unique constraint** + duplicate handling than thien, **EXPLAIN**/index, va **production safe error** + logging.

**Phan lam them (Cau 3 — duoc cong diem):**

- **CSRF token** cho moi form POST (create/update/delete/logout) qua `csrf_field()` + `verify_csrf()`.
- **Role permission**: chi admin duoc xoa lead/order; **staff** chi tao/sua (da test: staff POST delete khong xoa duoc).
- **Transaction** khi tao order (`beginTransaction/commit/rollBack`).
- **Dashboard thong ke**: tong lead, lead moi, tong phieu, doanh thu da thu, phan bo theo trang thai.
- **Filter theo status** ben canh search q.
- **Logging** vao `storage/logs/app.log` cho loi DB, login failed va honeypot.
- **Giao dien** polished, responsive (layout + partial dung chung) ma van giu dung kien truc MVC.

**Bang phu luc: requirements coverage**

| <b>Yeu cau</b>                                                        | <b>Dat</b> |
|-----------------------------------------------------------------------|------------|
| Front Controller / Router / 404 / 405                                 | ✓          |
| Form secure: validate server-side, old input, PRG                     | ✓          |
| Honeypot + rate limit cho form cong khai                              | ✓          |
| Login/logout/session regenerate/timeout/cookie flags                  | ✓          |
| Database users + 2 bang nghiep vu, PK/UNIQUE/INDEX/timestamp          | ✓          |
| PDO chuan (utf8mb4, EXCEPTION, FETCH_ASSOC, EMULATE=false)            | ✓          |
| Prepared statements cho moi input GET/POST                            | ✓          |
| CRUD Module A (leads) + Module B (orders), POST cho thao tac thay doi | ✓          |
| Search / pagination / sort whitelist an toan                          | ✓          |
| Duplicate handling khong lo SQLSTATE                                  | ✓          |
| EXPLAIN + nhan xet index                                              | ✓          |
| MVC: Controller mong, Service rule, Repository SQL, View escape       | ✓          |
| 404/405/500; production safe error + logging                          | ✓          |
| /health JSON app/db status                                            | ✓          |
| README + route list + demo account + cau truc folder                  | ✓          |
| Lam them: CSRF, role permission, transaction, dashboard, logging      | ✓          |

**GitHub:** <https://github.com/lphhien112-gif/PHP-Thu-muc>: PHP-Lab06/EduCRM/